Prompterly Security & Data Architecture — Task List

#	Section	Task	Description	Status
1	2.1 — Pseudonymisation	Assign `user_uuid` to all users	Each user account gets a unique internal identifier with no personal info	
2	2.2 — Data Separation	Separate identity data from content data	Identity fields (name, email, Stripe ID) in dedicated tables; content tables reference `user_uuid` only	
3	2.2 — Data Separation	Store separate tables per flow	Chat messages, notebook, time capsule, AI interaction tables must not contain name/email	
4	2.3 — Mapping	Store identity → uuid mapping in identity layer only	Mapping must not be duplicated across content tables	
5	2.4 — Access Restrictions	Restrict identity-content linking to authorised personnel	Admin tools linking identity + conversations require MFA	
6	2.5 — Logging	Sanitise system logs	Logs may include `user_uuid`, timestamps, metadata — must NOT include conversation text or PII	
7	2.6 — Data Export	Build user data export feature	Export chat history, notebook entries, time capsule entries in JSON/CSV/PDF	
8	2.7 — Data Deletion	Implement content deletion	Delete content from content tables when user deletes a thread/entry	
9	2.7 — Data Deletion	Implement account deletion	Anonymise PII, revoke auth credentials, keep pseudonymous content records	
10	3 — Encryption In Transit	Enforce HTTPS with TLS 1.2+	Auto-redirect HTTP→HTTPS, valid TLS certs, no insecure fallback	

11	3 — Encryption At Rest	Enable encryption at rest	AES-256 on database, object storage (S3), and backup storage	
12	3 — Encryption At Rest	Restrict DB to private network	Production DB must not be publicly accessible; connections via private network/security groups only	
13	3 — Sensitive Content Encryption	Application-level encryption for sensitive fields	Encrypt chat message content, notebook text, time capsule content before writing to DB	
14	3 — Sensitive Content Encryption	Use secure key management (KMS)	Encryption keys via AWS KMS or equivalent — never stored in application DB	
15	3 — Search	Implement thread-level search on encrypted content	Decrypt in app layer for search OR maintain a separate search index without full plaintext	
16	4 — Authentication	Hash passwords with bcrypt	Never store passwords in plain text	
17	4 — Authentication	Secure auth tokens	Defined expiration (hours, not months), secure storage, HTTPS-only transmission, invalidate on logout	
18	4 — Authentication	Implement role-based access + MFA for admin	Administrative access requires RBAC and multi-factor auth	
19	4 — Rate Limiting	Rate limit auth & sensitive API endpoints	Limit repeated login attempts per IP, block excessive failures, rate limit account recovery	
20	5 — Secrets Management	Move all secrets to secure storage	DB creds, API keys, Stripe keys, email creds → AWS Secrets Manager / Parameter Store / Vault	
21	5 — Secrets Management	Remove hardcoded credentials from code	No secrets in application source code	
22	6 — Backups	Automate daily database backups	At least once/day, stored separately, encrypted (AES-256), in secure cloud storage	

23	6 — Backup Retention	Configure backup retention policy	Daily backups: 30 days; Monthly backups: 12 months	
24	6 — Restore	Test backup restoration procedures	Periodically verify backups are functional and restorable	
25	7 — Data Retention	Implement 60-day log retention	System logs rotate daily, stored 60 days, auto-deleted unless legal hold	
26	7 — Data Retention	Retain audit logs for 12 months	Security and admin audit logs kept at least 12 months	
27	7 — Legal Hold	Build legal preservation mechanism	Admin ability to temporarily disable account data deletion for legal requests	
28	8 — Audit Logging	Log critical platform actions	Record account creation/deletion, admin actions, data deletion requests, subscription changes, security events	
29	9 — Audit Logging	Store audit logs separately	Audit logs separated from standard application logs	
30	10 — Data Export	Build user-facing export feature	Export chat, notebook, time capsule in JSON/CSV/PDF; exclude mentor branding if lounge removed	
31	11 — Stripe	Ensure no raw credit card storage	Only store Stripe customer ID, subscription ID, payment status	
32	11 — Stripe Webhooks	Validate Stripe webhooks signatures	Verify signatures, reject invalid, enforce timestamp tolerance against replay attacks	
33	12 — Minimum Age	Add age confirmation at signup	Checkbox: “I confirm that I am at least 18 years of age or older”	
34	13 — Incident Response	Build incident response procedures	Investigate promptly, secure systems, notify affected users as legally required	
35	14 — AI Data Boundaries	Prevent user data from training public AI models	User conversations must not be used for public AI model training	

36	14 — AI Data Boundaries	Add AI disclaimer	AI responses are not professional therapy, legal, or medical advice	
37	15 — Mentor IP Versioning	Implement config versioning for coaching lounges	Create new version on each change; preserve all previous versions (immutable)	
38	15 — Mentor IP Versioning	Record config version per chat session	Each chat session stores which configuration version generated responses	
39	15 — Mentor IP Versioning	Support config rollback	Rollback to previous version without modifying/deleting historical versions	
40	16 — Compliance	Comply with privacy frameworks	Australian Privacy Act, GDPR, CCPA/CPRA	
41	16 — Compliance	Update privacy policy	Disclose: data collected, how used, retention periods, deletion/export process	

Compliance Requirements

Privacy Frameworks

#	Framework	Jurisdiction	Key Requirements	Status
1	Australian Privacy Act	Australia	Data collection disclosure, user consent, data breach notification	
2	GDPR	European Union	Right to access, right to erasure, data portability, consent management, breach notification within 72hrs	
3	CCPA/CPRA	California, USA	Right to know, right to delete, opt-out of sale, data sale restrictions	

Privacy Policy Disclosure Requirements

#	Disclosure Item	Description	Status
1	What data is collected	Clearly list all categories of user data collected (PII, content, timestamps, device)	
2	How data is used	Explain purposes: service delivery, AI coaching, analytics, system improvement	
3	How long it is retained	Chat/notebook/time capsule: indefinite until deleted; system logs: 90 days; audit logs: 12 months; backups: 30 days daily / 12 months monthly	
4	How users may request deletion or export	Provide DSAR/DSR process (email or in-product request)	
5	Third-party services used	List OpenAI (AI), AWS (hosting), Stripe (payments), etc.	
6	International data transfers	Disclose if data is processed outside user's jurisdiction	

Platform-Level Compliance Tasks

#	Requirement	Section	Details	Status
1	Data Pseudonymisation	S.2	Content linked via user_uuid only, not PII	
2	Encryption in Transit	S.3	HTTPS with TLS 1.2+, auto HTTP → HTTPS redirect	
3	Encryption at Rest	S.3	AES-256 on DB, object storage, backups	
4	Application-Level Encryption	S.3	Encrypt chat messages, notebook, time capsule content before DB write	
5	Password Hashing	S.4	bcrypt, no plain text storage	
6	Auth Token Security	S.4	Expiration, secure storage, HTTPS-only, invalidate on logout	
7	Rate Limiting	S.4	Login, auth, account recovery endpoints	

8	Secrets Management	S.5	No hardcoded creds; use AWS Secrets Manager/KMS/Vault	
9	Daily Encrypted Backups	S.6	Stored separately, AES-256 encrypted, in secure cloud	
10	Data Retention & Log Rotation	S.7	60-day system logs, 12-month audit logs; defined retention per data type	
11	Account Deletion / Anonymisation	S.7	Anonymise PII, revoke auth, pseudonymous content retained	
12	Legal Hold Capability	S.8	Admin mechanisms to temporarily prevent data deletion	
13	Audit Logging	S.9	Log account creation/deletion, admin actions, security events; store separately	
14	User Data Export	S.10	Export chat, notebook, time capsule in JSON/CSV/PDF	
15	No Raw Credit Card Storage	S.11	Stripe handles all card data; only store Stripe IDs	
16	Stripe Webhook Validation	S.11	Signature validation, replay attack prevention	
17	Minimum Age Confirmation	S.12	18+ age checkbox at signup	
18	Incident Response Procedures	S.13	Investigate, secure, notify users as legally required	
19	AI Data Boundaries	S.14	User conversations never used for public AI training	
20	Mentor IP Versioning	S.15	Immutable config versions, per-session version tracking, rollback support	
21	Privacy Policy Update	S.16	Disclose collection, usage, retention, deletion/export rights	

Support Style Selector (Tone Modes) — Task List

#	Section	Task	Description	Status
1	DB Schema	Create support styles config table	Add table/config to store available tone modes (id, name, slug, description, prompt_snippet)	
2	DB Schema	Add selected style to user preferences	Add selected_support_style field to user preferences or chat session table	
3	API — Styles	GET available styles endpoint	GET /api/support-styles — return list of available tone modes (Motivational, Analytical, Empathetic)	
4	API — Styles	SET selected style endpoint	PATCH /api/user/preferences/support_style — save the user's chosen tone mode	
5	API — Styles	GET current selected style endpoint	GET /api/user/preferences/support_style — return the user's currently active tone mode	
6	API — Styles	Validate style input	Ensure only valid style slugs are accepted; reject invalid/malformed requests	
7	API — Styles	Rate limit style endpoints	Apply rate limiting to style selection endpoints to prevent abuse	
8	AI Prompt Integration	Define prompt snippet — Motivational	Encouraging, uplifting, action-oriented tone. Use affirmations, celebrate progress, push forward	
9	AI Prompt Integration	Define prompt snippet — Analytical	Logical, structured, reflective tone. Ask probing questions, break down problems, provide frameworks	
10	AI Prompt Integration	Define prompt snippet — Empathetic	Warm, understanding, validating tone. Acknowledge feelings, listen actively, offer emotional support	
11	AI Prompt Integration	Inject selected style into AI prompt context	When generating a coaching lounge response, append the selected style's prompt snippet to the system instructions	
12	AI Prompt Integration	Default style fallback	If no style is selected, default to a neutral/balanced tone (e.g., Motivational)	

13	AI Prompt Integration	Apply style per chat session	Ensure the selected style applies to the current and future messages in the active session	
14	AI Prompt Integration	Support mid-conversation style switch	User can change tone mid-conversation; new messages use the updated style, previous messages unchanged	
15	Frontend — Sidebar	Activate the Support Style toggle	Enable the currently visible but inactive Support Style toggle in the chat sidebar	
16	Frontend — Sidebar	Display 3 selectable tone modes	Show Motivational, Analytical, Empathetic as selectable options with name/icon	
17	Frontend — Sidebar	Persist selection via API	Call the SET endpoint on selection; reflect active state visually in the toggle	
18	Frontend — Sidebar	Load current style on page load	Fetch user's saved style on init and set the toggle to the correct active state	
19	Versioning (S.15 Compliance)	Version the style config	Create a new config version when tone prompt snippets are modified; preserve previous versions as immutable	
20	Versioning (S.15 Compliance)	Record config version per chat session	Each chat session stores which style config version was used to generate responses	
21	QA — Testing	Test — Style selection persists	Verify selected style is saved and retrieved correctly across sessions/page reloads	
22	QA — Testing	Test — AI tone adapts per style	Verify AI responses change tone based on Motivational vs Analytical vs Empathetic selection	
23	QA — Testing	Test — Mid-conversation switch	Verify switching style mid-chat applies new tone to subsequent messages only	
24	QA — Testing	Test — Default fallback	Verify correct default behavior when no style is selected	
25	QA — Testing	Test — Invalid style rejection	Verify API rejects invalid style slugs with proper error response	